

RAPPORT

ISAE3402 TYPE II

Edition – “Owlink by Tessi” - SaaS

Rapport sur l'évaluation de l'efficacité opérationnelle des contrôles généraux informatiques en place pour les activités d'édition autour du progiciel "Owlink by Tessi" proposé en mode SaaS par Owliance, élaboré en conformité avec la norme "International Standard on Assurance Engagements (ISAE 3402)" sur la période du 1er octobre 2022 au 30 septembre 2023

SOMMAIRE

SECTION I : INTRODUCTION	3
SECTION II : PREAMBULE AU RAPPORT DE L'AUDITEUR INDEPENDANT	5
SECTION III : RAPPORT DE L'AUDITEUR INDEPENDANT	10
SECTION IV : DECLARATION DE LA DIRECTION	15
SECTION V : DESCRIPTION DES ACTIVITES ET DE L'ENVIRONNEMENT DE CONTROLE	18
SECTION VI : OBJECTIFS DE CONTROLE	34
SECTION VII : OBJECTIFS DE CONTROLE, CONTROLES CLES ET TESTS D'EFFICACITE OPERATIONNELLE	37
SECTION VIII : AUTRES INFORMATIONS FOURNIES PAR OWLIANCE ET NON COUVERTES PAR L'OPINION DE L'AUDITEUR INDEPENDANT	51



SECTION I: INTRODUCTION

Ce rapport a été préparé conformément à la norme ISAE 3402 (International Standard on Assurance Engagement) édictée par l'IAASB (International Auditing and Assurance Standards Board). Mise en place le 15 juin 2011, ISAE 3402 est une norme permettant aux utilisateurs de prestations externalisées d'obtenir une assurance quant à la fiabilité du dispositif de contrôle interne autour de ces prestations de services (appréciation des prestations de tiers).

Ce rapport traite du dispositif de contrôle interne mis en place au sein d'Owliance (désormais intégrée au groupe Tessi pour former la Business Unit Tessi Assurances), et plus spécifiquement des contrôles considérés comme pertinents pour les clients (nommés ici comme "Utilisateurs de services") utilisant les services fournis par Owliance dans le cadre de l'édition du progiciel "Owlink by Tessi" en mode SaaS (Software as a Service) et devant fournir des informations à leurs auditeurs financiers pour les besoins de la certification de leurs propres comptes. Ce rapport ne traitera donc pas de l'ensemble des services fournis par Owliance.

Ce rapport se comprend les sections suivantes :

Section I	: Introduction
Section II	: Préambule au rapport de l'auditeur indépendant
Section III	: Rapport de l'auditeur indépendant
Section IV	: Déclaration de la Direction
Section V	: Description des activités et de l'environnement de contrôle par l'auditeur indépendant
Section VI	: Récapitulatif des objectifs de contrôle
Section VII	: Contrôles clés et tests effectués afin de s'assurer que ces contrôles sont conçus et mis en œuvre afin d'atteindre les objectifs de contrôle
Section VIII	: Autres informations fournies par Owliance et non couvertes par l'opinion de l'auditeur indépendant

Ce rapport sera centré sur les contrôles mis en place par Owliance son activité d'édition du progiciel "Owlink by Tessi" en mode SaaS.

L'objectif du contrôle interne est de donner une assurance raisonnable, mais non absolue quant à la réalisation/l'atteinte de certains objectifs de contrôle. La Direction d'Owliance est responsable de l'identification des objectifs de contrôle interne et de la mise en place des contrôles permettant de répondre aux objectifs définis.

SECTION II :
**PREAMBULE AU
RAPPORT DE
L'AUDITEUR
INDEPENDANT**

1. INTRODUCTION

Ce rapport sur le dispositif de contrôle interne encadrant les services aux clients autour des activités d'édition du progiciel "Owlink by Tessi" en mode SaaS a pour objectif de permettre à tous les tiers intéressés de comprendre le traitement de leurs transactions, ainsi que l'efficacité opérationnelle autour de ces traitements. Ainsi ce rapport, une fois associé à une correcte compréhension des contrôles en place chez les utilisateurs de ces services, a pour objectif de faciliter l'appréciation des risques de contrôle pour les besoins des clients d'Owliance utilisateurs de la solution "Owlink by Tessi" en mode SaaS (les "Clients") et des auditeurs de ces Clients, lors de l'établissement par les Clients de leurs propres états financiers ainsi que lors de la préparation de leur audit par les auditeurs desdits Clients.

Les tests de l'auditeur indépendant sont limités aux objectifs de contrôle et aux contrôles qui y sont associés tels que décrits par Owliance dans la **section VII** de ce rapport, contrôles considérés par la Direction d'Owliance et nous-mêmes comme les contrôles-clés pour atteindre les objectifs de contrôle retenus par Owliance pour les activités couvertes par ce rapport. Cette description s'applique à l'ensemble des opérations liées aux contrôles dédiés à l'édition du progiciel "Owlink by Tessi" en mode SaaS tels qu'ils ont été exercés au cours de la période du 1er octobre 2022 au 30 septembre 2023. Cette vérification a été effectuée conformément aux dispositions prévues par la norme internationale d'audit "International Standard on Assurance Engagements (ISAE) 3402".

Il est de la responsabilité de tout tiers intéressé d'apprécier les informations ainsi produites dans ce rapport en relation avec le dispositif de contrôle interne en place chez chaque utilisateur des services d'Owliance, comme souligné en **section V**, pour les besoins de l'évaluation du dispositif de contrôle interne. Ainsi, en cas d'absence de certains contrôles au sein du dispositif de contrôle interne chez l'utilisateur des services d'Owliance, les contrôles mis en place par Owliance n'ont pas vocation à compenser cette absence.

L'objectif du contrôle interne est de donner une assurance raisonnable, mais non absolue quant aux traitements des opérations des clients et donc sur la fiabilité susceptible d'être accordée aux enregistrements comptables ayant une incidence sur les états financiers. La notion d'assurance raisonnable inclut le principe que le coût du contrôle ne doit pas excéder les bénéfices espérés par sa mise en place, mais également que l'évaluation de ces critères requiert nécessairement une estimation et un jugement de la part de la Direction.

Faisant partie intégrante des procédures de vérification du dispositif de contrôle interne d'Owliance autour du progiciel "Owlink by Tessi" en mode SaaS, des tests mesurant l'efficacité opérationnelle ont été effectués selon des méthodes procurant différents niveaux de confort d'audit. Le résultat agrégé de ces tests constitue la base de la compréhension de l'organisation des contrôles sous l'hypothèse confirmée par la Direction d'Owliance que ces contrôles encadrant l'édition du progiciel "Owlink by Tessi" en mode SaaS, sont mis en œuvre au cours de la période du 1er octobre 2022 au 30 septembre 2023 pour fournir l'assurance raisonnable d'un traitement approprié des transactions au cours de cette période.

2. ENVIRONNEMENT DE CONTROLE

L'environnement de contrôle est l'effet conjugué de différents éléments visant à instaurer, améliorer ou diminuer l'efficacité de contrôles spécifiques au sein d'une société, notamment :

- Sa structure organisationnelle et sa politique de séparation des tâches ;
- Le fonctionnement de ses organes de décision et de ses différents comités ;
- Les moyens de contrôle dont s'est dotée la Direction ;
- Les politiques et procédures encadrant le personnel ;
- Le code d'éthique ;
- Le rôle des départements de contrôle interne et de la conformité dans l'élaboration des procédures visant à collecter et traiter les réclamations ayant trait au contrôle interne ;
- L'audit interne ;
- Et la supervision par les Autorités de tutelle.

L'examen d'un environnement de contrôle comprend les procédures suivantes, dans la mesure où elles sont considérées comme nécessaires :

- Une revue de l'organisation de l'établissement, y compris la séparation des responsabilités fonctionnelles, les procédures en vigueur, les manuels de procédures opérationnelles et comptables, les procédures relatives au personnel, ainsi que les rapports et procédures d'audit interne ;
- Des échanges avec la Direction, avec les responsables opérationnels et administratifs en charge du développement et du contrôle de l'adhésion et de la correcte application des contrôles ;
- L'Inspection des opérationnels dans le cadre de la réalisation des tâches qui leur sont assignées ;
- Une revue des actions entreprises par la Direction en réponse aux recommandations émises par l'audit interne pour améliorer les contrôles.

L'environnement de contrôle a été pris en compte pour déterminer la nature, l'étendue et le calendrier des travaux de tests d'efficacité opérationnelle des contrôles pertinents pour atteindre les objectifs de contrôle.

3. CONTROLES

Les tests de l'efficacité opérationnelle des contrôles incluent les vérifications que nous avons jugé nécessaires en la circonstance pour apprécier si ces contrôles étaient suffisants pour donner l'assurance raisonnable, mais non absolue, que les objectifs de contrôle spécifiés dans ce rapport ont été atteints au cours de la période du 1er octobre 2022 au 30 septembre 2023.

Les tests d'efficacité opérationnelle des contrôles ont été conçus pour couvrir au cours de la période du 1er octobre 2022 au 30 septembre 2023 un nombre représentatif de transactions et de procédures, au titre des contrôles mentionnés en **section VII**, visant à permettre l'atteinte des objectifs de contrôle décrits en **section VI**.

Dans le choix des méthodes de vérification visant à tester la conception de ces contrôles, nous avons considéré les aspects suivants :

- La nature des contrôles à tester ;
- La nature des objectifs de contrôle à atteindre ;
- L'appréciation du niveau de risque de contrôle ;
- La pertinence et l'efficacité attendue du test de contrôle ;
- La méthode de tests retenue pour tester les autres contrôles concourant à l'objectif de contrôle visé.

La nature des tests mis en œuvre pour vérifier l'efficacité opérationnelle des contrôles au sein d'Owliance tels que détaillés en **section VII**, peut être brièvement décrite comme suit :

Type	Description
Entretien	S'entretenir avec le personnel approprié pour obtenir des informations pertinentes sur les contrôles effectués ou la confirmation que ces contrôles l'ont été, y compris notamment : - Prendre connaissance, obtenir des informations complémentaires et des affirmations portant sur les règles et procédures de contrôle ; - Recouper des preuves de l'existence de règles et procédures de contrôle ; - Comprendre l'attitude générale du personnel vis-à-vis de l'environnement de contrôle
Observation	Observer la réalisation ou l'existence des contrôles spécifiques tels que décrits
Inspection	Inspecter des documents ou des enregistrements indiquant la réalisation des règles et procédures de contrôle, y compris notamment : - Prendre connaissance, obtenir des informations complémentaires et des affirmations portant sur les règles et procédures de contrôle ; - Recouper des preuves de l'existence de règles et procédures de contrôles ; - Comprendre l'attitude générale du personnel vis-à-vis de l'environnement de contrôle
Reperformance	Réexécuter le contrôle ou la procédure de contrôle appliquée pour s'assurer de l'exactitude de l'opération. Cela peut notamment inclure : - D'obtenir la preuve de l'exactitude arithmétique et du traitement correct de transactions par la réalisation de calculs indépendants ; - De refaire le rapprochement de données en provenance de plusieurs systèmes et comparer le résultat de ce rapprochement aux écarts identifiés lors de l'exécution du contrôle

Taille des échantillons de tests

Chaque fois que nous avons utilisé un échantillon pour étayer le test d'efficacité opérationnelle des contrôles décrits à la **section VII**, nous avons tenu compte des éléments suivants :

La taille minimale des échantillons utilisés pour tous les échantillons sélectionnés est égale ou supérieure aux tailles minimales d'échantillons suggérées par le guide d'audit de l'AICPA dans ses considérations sur l'échantillonnage des missions d'audit. A titre d'exemple, une taille d'échantillon de 25 occurrences au minimum est obligatoire pour les populations supérieures à 250 éléments, et donc pour les contrôles pluriquotidiens.

Le tableau suivant présente la gamme des tailles d'échantillon utilisées. La taille des échantillons retenus est ajustée en fonction de divers facteurs, tels que, entre autres, les exceptions observées dans le passé, les changements substantiels dans les processus associés aux procédures de contrôle et le niveau d'assurance souhaité. De plus, nous avons utilisé notre jugement professionnel au regard des circonstances pour ajuster à la hausse, le cas échéant, la taille de l'échantillon dans les fourchettes décrites ci- dessous :

Fréquence	Taille de la population	Taille de l'échantillon
Plusieurs fois par jour	$P > 250$	[25-60]
Quotidien	$P = 250$	[20-40]
Population entre 52 et 250 items	$52 < P < 250$	Environ 10% de la population avec un minimum de 5 items
Hebdomadaire	$P < 52$	[5-15]
Mensuel	$P < 12$	[2-5]
Trimestriel	$P < 4$	2
Annuel	$P = 1$	1

SECTION III :
**RAPPORT DE
L'AUDITEUR
INDEPENDANT**



Tessi Assurances (aussi appelée Owlance)
27-33 quai Alphonse Le Gallo
92100 Boulogne Billancourt

A l'attention de Monsieur Dominique Trichard,
Directeur Général Tessi Assurances

Périmètre

Nous avons examiné la description préparée par Owlance en **sections V et VI** du présent rapport (la "Description") portant sur l'organisation mise en place par Owlance pour les utilisateurs du progiciel "Owlink by Tessi" en mode SaaS sur toute ou une partie de la période du 1er octobre 2022 au 30 septembre 2023 (la "Période") ainsi que la pertinence, la réalité et l'efficacité opérationnelle sur la Période des contrôles mis en œuvre afin de répondre aux objectifs de contrôle associés qui y sont décrits sur la base des critères déclarés par la direction d'Owlance (la "Déclaration") en **section IV**.

Les objectifs de contrôle et les contrôles figurant dans la Description sont ceux que la direction d'Owlance a jugé les plus pertinents pour les utilisateurs du progiciel "Owlink by Tessi" en mode SaaS ; la Description ne reprend en revanche pas tous les aspects des contrôles et objectifs de contrôle retenus par Owlance dans le cadre de ses autres activités.

Owlance a recours à certains prestataires de services informatiques dans le cadre de l'hébergement et exploitation des serveurs du progiciel "Owlink by Tessi" en mode SaaS. La Description inclut seulement les objectifs de contrôle et contrôles clés définis par Owlance et exclut les objectifs de contrôle et contrôles mis en place par ces prestataires de services.

Les éléments d'information figurant en **section VIII** du rapport sont présentés par la direction d'Owlance en vue de fournir des compléments d'information aux utilisateurs du progiciel "Owlink by Tessi" en mode SaaS, mais ne sont pas partie intégrante de la Description. Ces éléments n'ont fait l'objet d'aucune diligence de notre part et nous n'exprimons en conséquence aucune opinion à leur égard.

La Description du dispositif indique en **section V** qu'il revient aux utilisateurs du progiciel "Owlink by Tessi" en mode SaaS de mettre en place les contrôles appropriés en fonction de leur propre organisation, sans lesquels les objectifs de contrôle décrits dans le présent rapport ne seraient pas atteints, étant rappelée la configuration du dispositif de contrôle interne mis en œuvre au sein d'Owlance. Nous n'avons pas examiné la pertinence des contrôles chez les utilisateurs des services d'Owlance.

PricewaterhouseCoopers Audit, 63, rue de Villiers, 92208 Neuilly-sur-Seine Cedex

Téléphone : +33 (0)1 56 57 58 59, Fax : +33 (0)1 56 57 58 60, www.pwc.fr

Société d'expertise comptable inscrite au tableau de l'ordre de Paris - Ile de France, Société de commissariat aux comptes membre de la compagnie régionale de Versailles. Société par Actions Simplifiée au capital de 2 510 460 €. Siège social : 63, rue de Villiers 92200 Neuilly-sur-Seine. RCS Nanterre 672 006 483. TVA n° FR 76 672 006 483. Siret 672 006 483 00362. Code APE 6920 Z. Bureaux : Bordeaux, Grenoble, Lille, Lyon, Marseille, Metz, Nantes, Neuilly-sur-Seine, Nice, Poitiers, Rennes, Rouen, Strasbourg, Toulouse.

Responsabilité d'Owliance

En **section IV** figure la déclaration de la direction d'Owliance s'engageant sur l'image fidèle de la Description, y compris pour ce qui est de la pertinence, de l'existence et de l'efficacité opérationnelle au cours de la période du 1er octobre 2022 au 30 septembre 2023 des contrôles visant à répondre aux objectifs de contrôle qui y sont décrits.

Owliance est responsable de l'établissement de la Description et de la Déclaration, notamment en matière d'exhaustivité, exactitude et méthode de présentation des éléments retenus dans la Description et la Déclaration, de délivrance des services présentés dans la Description, de définition des objectifs de contrôle présentés dans la Description, d'identification des risques susceptibles de compromettre l'atteinte des objectifs de contrôle, de sélection des critères retenus dans la Déclaration, ainsi qu'en matière d'élaboration, mise en œuvre et documentation des contrôles conçus pour répondre aux objectifs de contrôle figurant dans la Description dès lors que ces contrôles sont en place et qu'ils opèrent efficacement.

Responsabilité de PricewaterhouseCoopers Audit

Il nous appartient, sur la base de nos travaux, d'émettre une opinion sur la fidélité de la présentation de la Description figurant dans le rapport, ainsi que sur la pertinence et l'efficacité opérationnelle des contrôles qui y sont décrits pour répondre aux objectifs de contrôle associés sur la période du 1er octobre 2022 au 30 septembre 2023.

Nous avons effectué nos travaux dans le respect de la norme internationale ISAE 3402 ("Assurance Reports on Controls at a Service Organisation"), établie par le Conseil des normes internationales d'audit et d'assurance (IAASB). Cette norme requiert la mise en œuvre de diligences professionnelles permettant d'obtenir l'assurance raisonnable que les contrôles, tels que décrits dans le rapport, sont correctement conçus et opérationnels, dans tous leurs aspects significatifs, pour répondre aux objectifs de contrôle sur la période du 1er octobre 2022 au 30 septembre 2023.

Nous estimons que nos travaux fournissent une base raisonnable à l'opinion avec réserves exprimée ci-après.

Indépendance et Contrôle Qualité

Nos travaux ont été effectués dans le respect des règles d'éthique et d'indépendance prévues par notre code de déontologie (Code of Ethics for Professional Accountants) élaboré par l'International Ethics Standards Board for Accountants (IESBA). Celui-ci repose sur le respect des principes d'intégrité, d'objectivité, de compétence et diligence professionnelles, de respect de la confidentialité et du comportement professionnel.

En application de la norme internationale de contrôle qualité (International Standard on Quality Control 1) nous avons mis en œuvre un système complet de contrôle qualité comprenant des politiques et des procédures écrites visant à assurer le respect des règles déontologiques, des normes professionnelles et des exigences légales et réglementaires applicables.

Limites inhérentes

La Description des contrôles d'Owliance telle que figurant dans le Rapport, a été préparée afin de répondre aux attentes générales d'un large panel d'utilisateurs. En conséquence, cette

Description peut ne pas inclure certains aspects du dispositif de contrôle susceptibles d'être importants pour un client donné dans son environnement particulier.

Du fait de leur nature, les contrôles mis en œuvre sont susceptibles de ne pas systématiquement prévenir, détecter ou corriger les erreurs ou omissions dans le traitement ou la restitution des informations. En outre, toute projection dans le futur du résultat de l'évaluation de la fidélité de la Description, ainsi que des conclusions portant sur la pertinence de l'élaboration et la mise en œuvre des contrôles visant à répondre aux objectifs de contrôle qui y sont associés, est soumise au risque que lesdits contrôles deviennent insuffisants ou défaillants.

Description des tests de contrôle

Les contrôles spécifiques testés, ainsi que la nature, le calendrier et les résultats de ces tests figurent en **section VII**.

Fondement de l'opinion avec réserves

Dans sa Description des contrôles autour des services délivrés par Owlance à ses clients utilisateurs desdits services, il est précisé :

- Pour le Contrôle **CO09**, que l'état des traitements automatiques était suivi par l'équipe d'exploitation Owlance de manière quotidienne, en accord avec le plan d'exploitation défini mensuellement, et qu'en cas d'erreurs de traitement, ces dernières étaient tracées dans un ticket, investiguées et résolues par les équipes dédiées. Or, nous n'avons pas été en mesure d'obtenir les tickets correspondant à l'échantillon de 20 incidents de traitement sélectionnés ;

En conséquence, nous ne sommes pas en mesure de conclure que **l'objectif de contrôle #5 "Les contrôles fournissent une assurance raisonnable que les traitements automatiques des systèmes supportant la plateforme SaaS Owlance sont autorisés et exécutés sans erreurs, et en temps opportun, et que les problèmes et erreurs identifiés, sont suivis, enregistrés et résolus en temps opportun."** a été atteint au cours de la Période.

Opinion avec réserves

A notre avis, sur la base des critères retenus par la direction d'Owlance tels que décrits en **section IV**, dans tous ses aspects significatifs, à l'exception des faits relatés dans les paragraphes ci-dessus relatifs à l'atteinte **de l'objectif de contrôle #5** dans la section "**Fondement de l'opinion avec réserves**" du rapport :

- La Description des contrôles figurant dans le rapport donne une image fidèle du dispositif de contrôle interne effectivement mis en œuvre au sein d'Owlance autour des activités d'édition du progiciel SaaS "Owlink by Tessi" au cours de la Période ;
- Les contrôles répondant aux objectifs de contrôle tels que décrits dans le rapport permettent de donner l'assurance raisonnable que ces objectifs de contrôle seraient atteints si les contrôles opéraient effectivement au cours de la Période, et que les clients utilisateurs des services d'Owlance avaient mis en œuvre les contrôles sous leur responsabilité au cours de la Période ;

- Les contrôles décrits dans le rapport ont opéré efficacement au cours de la Période pour donner une assurance raisonnable que les objectifs de contrôle ont été atteints dès lors que les contrôles complémentaires présumés exister chez les clients des services d'Owliance ont opéré efficacement au cours de la Période.

Diffusion restreinte

Ce rapport, y compris la Description en **section VII** des tests de contrôles et de leurs résultats, est réservé aux utilisateurs des services rendus par Owliance au titre de ses activités d'édition autour du progiciel "Owlink by Tessi" en mode SaaS sur la période du 1er octobre 2022 au 30 septembre 2023, ainsi qu'à leurs auditeurs externes, parce que ces derniers ont une compréhension suffisante de la nature et de l'étendue de ces services ainsi que des contrôles mis en place par les utilisateurs de ces services dans le cadre de l'appréciation des risques d'erreurs matérielles dans les états financiers desdits utilisateurs.

Ce rapport n'est pas destiné à être utilisé par d'autres utilisateurs que ceux mentionnés ci-dessus.

S'il venait à être utilisé par des personnes qui ne seraient pas les utilisateurs légitimes de ce rapport tels que définis dans la Déclaration en **section IV**, mais auraient été destinataires ou auraient eu accès à ce rapport, ces autres utilisateurs ne pourraient s'appuyer sur le présent rapport ni prétendre à aucun droit à l'encontre de PricewaterhouseCoopers Audit qui décline toute responsabilité à leur égard.

Neuilly-sur-Seine, le 26 mars 2024
PricewaterhouseCoopers Audit

 **Nicolas LE MOUAL**

Nicolas Le Moual
Associé

 *Jean de Laforcade*

Jean de Laforcade
Associé – IT Risk Services

SECTION IV :
**DECLARATION DE
LA DIRECTION**

Déclaration de Tessi Assurances (aussi dénommée Owlance)

La description du dispositif de contrôle interne présentée ci-après recouvre les services d'Owlance présentés en **section V** (La "Description") pour les activités d'édition du progiciel "Owlink by Tessi" en mode SaaS édité par Owlance sur la période du 1er octobre 2022 au 30 septembre 2023.

Elle a été préparée à l'attention d'utilisateurs légitimes, tels que définis au paragraphe suivant. En effet, ces utilisateurs légitimes ont une connaissance suffisante des services fournis par Owlance, y compris les contrôles opérés par les entités utilisatrices du progiciel, ainsi que des interactions du dispositif de contrôle interne d'Owlance, tel que décrit dans le présent rapport, avec le dispositif de contrôle interne mis en place par les utilisateurs de ces services, pour leur propre besoin d'évaluation des risques dans l'établissement de leurs propres états financiers.

Les utilisateurs de ce rapport sont, de manière limitative :

- (i) Owlance, sa direction, ses auditeurs externes et le régulateur
- (ii) Les clients d'Owlance pour lesquels Owlance a assuré la mise à disposition / l'édition du progiciel "Owlink by Tessi" en mode SaaS sur la période du 1er octobre 2022 au 30 septembre 2023.

La Description du dispositif de contrôle interne figurant en **section V** présente fidèlement le dispositif mis en place au sein d'Owlance autour de la mise à disposition / l'édition du progiciel "Owlink by Tessi" en mode SaaS sur la période du 1er octobre 2022 au 30 septembre 2023.

Les critères retenus pour sous-tendre les informations données dans le rapport ci-joint, reposent sur le fait que la Description y figurant :

- a. Présente la manière dont le dispositif a été conçu et les contrôles mis en œuvre, notamment pour ce qui est :
 - Des types de services fournis à nos clients, y compris le cas échéant, les types de transactions traitées ;
 - Des procédures, incluant les systèmes d'information ou les procédures manuelles par lesquelles ces transactions ont été initiées, enregistrées, traitées, corrigées autant que de besoin, et intégrées dans les états de reporting préparés pour nos clients ;
 - Des enregistrements comptables et les justificatifs utilisés pour initier, enregistrer, traiter et établir les états de reporting sur les transactions, y compris la correction d'informations erronées et leur prise en compte dans les états de reporting préparés à l'attention de nos clients ;
 - Du mode de gestion par le dispositif en place des événements et conditions, autres que les transactions ;
 - Du processus d'élaboration des états de reporting préparés à l'attention de nos clients ;
 - Des objectifs de contrôle pertinents et des contrôles qui leur sont associés pour y répondre ;
 - Des contrôles devant être mis en place par les utilisateurs de nos services, sans lesquels les objectifs de contrôle décrits dans le présent rapport ne seraient pas atteints, étant rappelé la configuration du dispositif de contrôle interne mis en œuvre au sein de notre établissement ;
 - Des autres aspects de notre environnement de contrôle, du processus d'évaluation des risques, du système d'informations (y compris les processus métiers associés), de communication, des activités de contrôle et de pilotage des

contrôles considérés comme appropriés pour le traitement des transactions de nos clients et leur reporting.

- b. Inclut tous les détails pertinents relatifs à l'organisation de notre dispositif de contrôle interne sur la période du 1er octobre 2022 au 30 septembre 2023 pour la délégation de gestion des prestations santé et prévoyance et la délégation de gestion des contrats santé et prévoyance.
- c. Ne présente pas d'informations incomplètes ou erronées concernant le périmètre du dispositif de contrôle décrit. Cette Description a été préparée afin de répondre aux objectifs de contrôle généralement retenus par un large nombre d'utilisateurs de nos services, ainsi que par leurs auditeurs externes ; elle peut donc ne pas inclure certains aspects du contrôle interne pertinents pour un client donné dans un contexte spécifique.

Les contrôles liés aux objectifs de contrôle décrits dans le rapport ci-joint ont été conçus de manière appropriée et étaient opérationnels sur la période du 1er octobre 2022 au 30 septembre 2023 pour l'édition du progiciel "Owlink by Tessi" en mode SaaS.

Les critères retenus pour sous-tendre les informations données dans le rapport ci-joint reposent sur le fait que :

- a. Les risques susceptibles d'entraver l'atteinte des objectifs de contrôle figurant dans le présent rapport ont été identifiés ;
- b. Les contrôles identifiés dans la description, sous réserve qu'ils ont été mis en œuvre conformément à leur Description, ont fourni l'assurance raisonnable que ces risques n'ont pas empêché les objectifs de contrôle en place d'être atteints, et que ces contrôles ont été, y compris les contrôles manuels, réalisés par des collaborateurs appropriés ayant l'autorité pour le faire sur la période du 1er octobre 2021 au 30 septembre 2022 pour l'édition du progiciel "Owlink by Tessi" en mode SaaS.
- c. La direction d'Owliance confirme que leurs équipes opérationnelles sont en capacité d'assurer la continuité de service en cas d'événements les empêchant de se rendre sur leur lieu de travail (pandémie, grève de transports, etc.) En effet, la poursuite de l'exécution des tâches critiques a été rendue possible grâce à l'amélioration des capacités de nos équipes, sur tous nos sites d'exploitation, qui ont désormais la capacité de travailler à domicile sans aucune exception. A cet égard, leur environnement de travail a été adapté au travail à domicile, sans modification substantielle de l'organisation des contrôles telle que décrite dans le présent rapport ISAE 3402 dans l'objectif de maintenir la qualité des contrôles et d'assurer un niveau de contrôle approprié.

Boulogne Billancourt, le 26 mars 2024

 **Dominique Trichard**

Dominique Trichard
Directeur Général Tessi Assurances

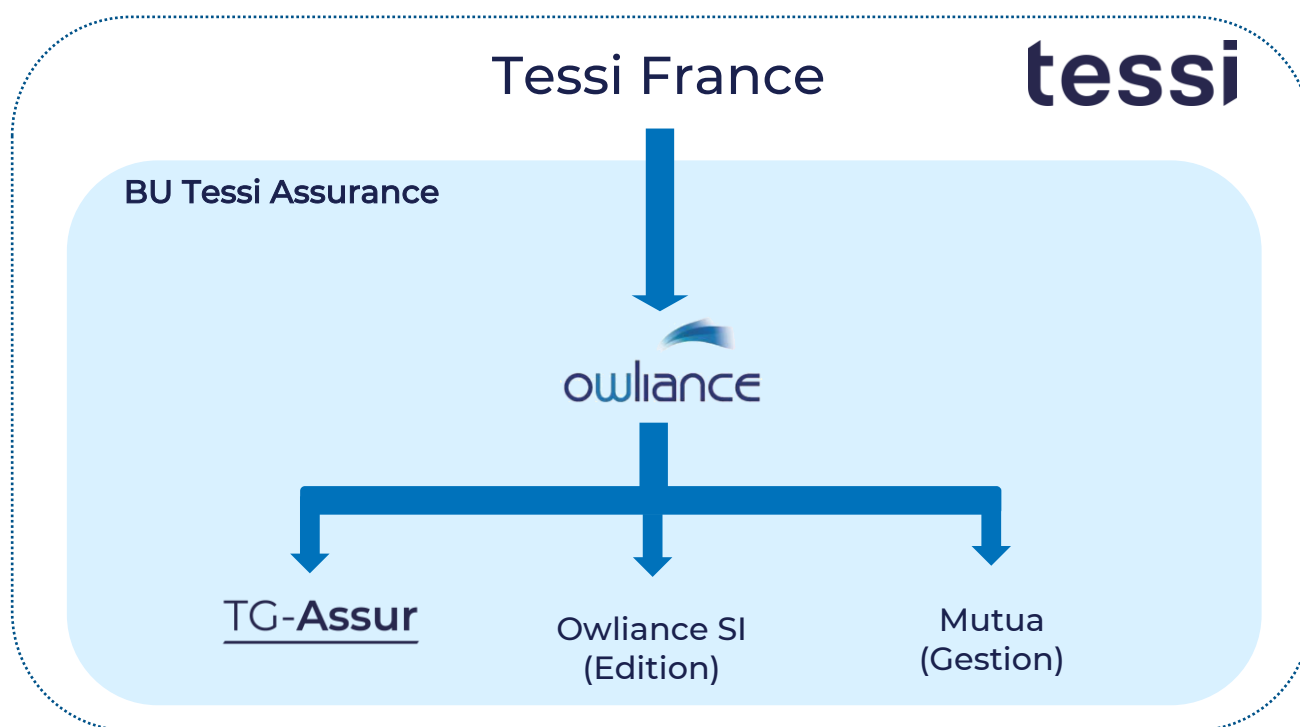
SECTION V :
**DESCRIPTION DES
ACTIVITES ET DE
L'ENVIRONNEMENT
DE CONTROLE**

1. PRESENTATION D'OWLIANCE

Owliance, une marque du groupe TESSI.

Créée en 1986, Owliance est une société spécialisée dans la délégation de gestion des contrats d'assurance santé et de prévoyance. Depuis son intégration dans le groupe Tessi en 2018, Owliance est une marque de la Business Unit Tessi Assurances.

Le groupe s'organise ainsi :



L'activité de la société s'organise autour de quatre pans différents :

- La délégation de gestion totale,
- La délégation de gestion partielle,
- La gestion des écrans connectés,
- L'édition de logiciel

Owliance propose une offre à destination de l'ensemble des acteurs du marché de l'assurance Santé Prévoyance : assureurs, bancassureurs, courtiers, mutuelles et institution de prévoyance. Elle accompagne environ une centaine de clients et sa solution Owlink gère plus de 2,6 millions de personnes.

Chiffres clés

Le groupe Tessi a réalisé au titre de l'année 2022 un chiffre d'affaires de **512 M€** et comprend plus de 13.000 collaborateurs.

2. DESCRIPTION DE L'ORGANISATION D'OWLIANCE

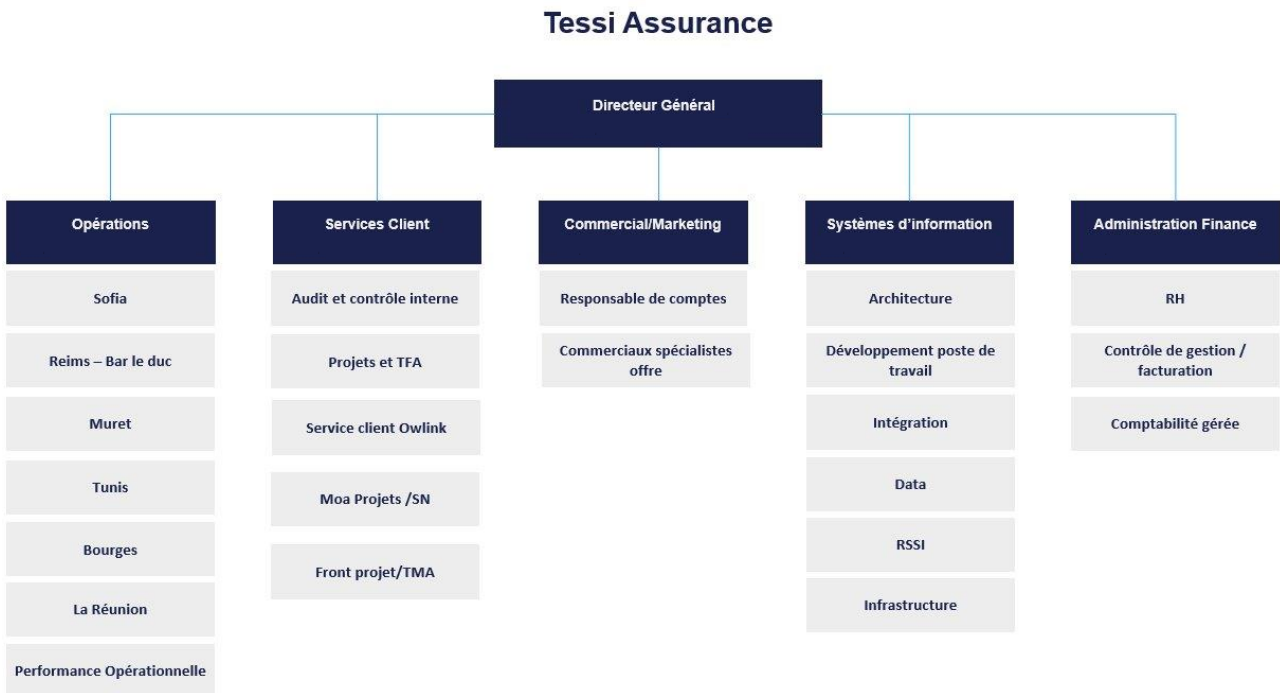
Le groupe Tessi

Marque du groupe TESSI France depuis 2018, la BU Tessi Assurances s'organise sous le contrôle de Dominique Trichard, Directeur Général.



2.1. L'organisation d'Owliance au sein de Tessi Assurance

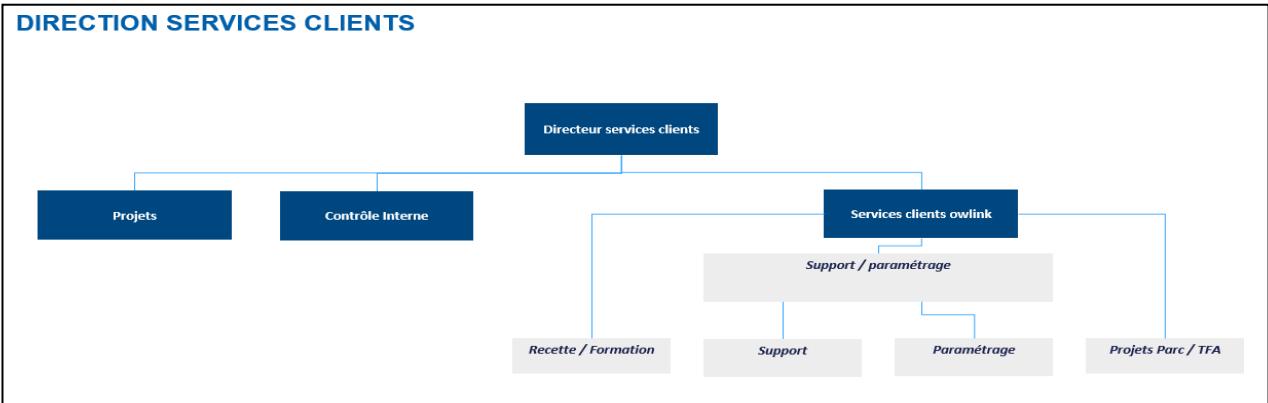
Owliance SI est une filiale d'Owliance SAS, qui met à disposition une partie des salariés de sa Direction des systèmes d'information. Sous la direction du DSI OSI et la surveillance du RSSI, l'organisation de l'équipe en charge du développement est décrite ci-après.



2.2. Principales activités d'Owliance au sein de Tessi Assurance

La maîtrise de la qualité

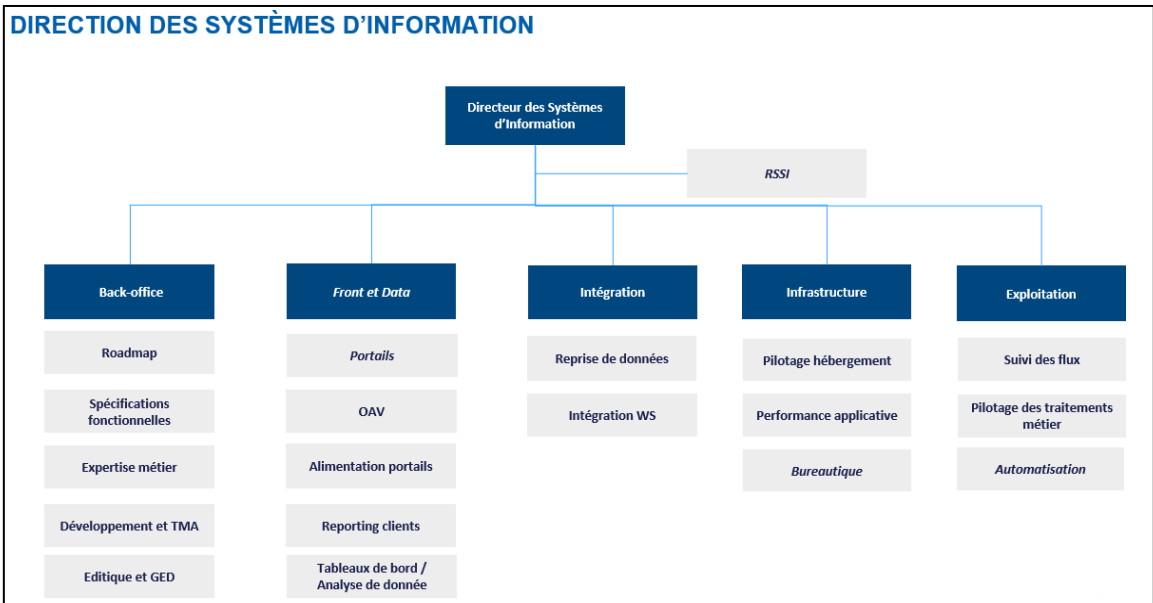
Afin d'assurer une démarche continue de qualité et une maîtrise des risques, le service clients d'Owliance est composé d'un service de contrôle interne en charge de réaliser différents contrôles de second niveau.



Quatre personnes ont actuellement la charge au sein de Tessi Assurances d'assurer la mission de contrôle interne.

L'édition

L'édition du logiciel Owlink est effectuée par la Direction des systèmes d'information.



3. OWLIANCE SERVICES INFORMATIQUES

3.1. Présentation d'Owliance Services Informatiques

Créée en 2009, Owliance Services Informatiques est une société spécialisée dans l'édition de logiciels destinés aux acteurs de la santé. La principale activité d'O.S.I consiste à développer et à implémenter la solution Owlink by Tessi auprès de ses clients.

Elle est également une filiale de la SAS Owliance, spécialiste de la délégation de gestion. Ces deux entités constituent donc des offres complémentaires pour les assureurs, bancassureurs et mutuelles. Depuis son intégration dans le groupe Tessi en 2018, Owliance est une marque de la BU Tessi Assurances.

Description des services fournis par Owliance à travers le progiciel Owlink

Owlink By Tessi est une application qui permet :

- une gestion complète des contrats client (vie du contrat, cotisations, prestations, historisation des demandes de l'adhérent) sur de l'assurance individuelle et collective,
- l'obtention d'états de reporting réglementaires,
- une gestion conforme à la réglementation Solvabilité II,
- une gestion de la fraude et du recours contre des tiers,
- une forte modularité permettant des interfaces avec plusieurs solutions de tiers-payant ainsi que les principaux réseaux de soins.

L'application est également complétée par plusieurs composants permettant à la solution d'avoir de multiples caractéristiques comme :

- un portail adhérent et entreprise en marque blanche,
- une GED entrante et sortante,
- une gestion de l'éditique (Indexation GED, workflow...),
- une plateforme décisionnelle,
- la création d'état de reporting.

Owlink a été conçu pour assurer une interopérabilité avec le SI du client.

4. DESCRIPTION DE L'ENVIRONNEMENT DE CONTROLE D'OWLIANCE

4.1. Périmètre du rapport

Le présent rapport décrit les activités et contrôles associés à l'édition de logiciel dédié à la santé. Afin de prévenir la survenance de risques opérationnels et de minimiser leur impact, un dispositif de contrôle interne est déployé par le Pôle Assurances.

Les familles de risques identifiés sont les suivantes :

- risque qualité,
- risque lié au développement des versions et à la gestion des changements,
- risques liés à la sécurité et à la continuité d'exploitation,
- risque lié à la gestion de l'exploitation.

4.2. Maîtrise de la qualité

La maîtrise de la qualité permet de pérenniser les relations avec les clients et la mise à jour en continu de l'outil face aux enjeux réglementaires.

La non-maîtrise de la qualité se définit comme le risque de ne pas détecter le besoin d'un client (qu'il soit réglementaire ou propre à son portefeuille) et de ne pas répondre dans un délai satisfaisant.

En réponse à ce risque, Owlance dispose de trois axes majeurs d'actions.

- Le premier axe de ce processus s'effectue par la tenue de comités visant à suivre les demandes des clients et à prendre les principales décisions stratégiques quant à leurs demandes.
- Le second axe est lié au suivi de la relation client.
- Le dernier axe concerne le suivi de la qualité des actions menées par les prestataires essentiels (PSEE).

Les comités au sein d'Owlance

Le pôle Tessi Assurances tient un comité annuel (cercle qualité) permettant de réaliser un point de situation sur l'année écoulée et de projeter sur la prochaine année les besoins réglementaires ou formulés par les clients.

Ce comité annuel est également complété par une instance mensuelle nommée « point road map ». Réalisée avec le représentant de chaque client souhaitant y participer, cette réunion a pour but de faire un point sur l'avancement des évolutions et des éventuelles montées de versions en cours et à venir.

En complément de ces instances orientées vers les clients, la DSI organise également des comités opérationnels mensuels avec l'hébergeur. Cette réunion a pour but de revoir les principaux indicateurs relatifs à l'activité d'hébergement (incidents, problèmes, capacité) et de veiller au respect des SLA définis dans le contrat.

La gestion de la relation client

Le service client du pôle Tessi Assurances se divise en différentes fonctions à savoir :

- le support,
- le paramétrage,
- la recette,
- la formation.

Le service support a la charge de recueillir l'ensemble des demandes des clients via un outil de ticketing nommé « JIRA ». Un service de hotline est également disponible sur différents créneaux de la journée. Il est à noter que l'ensemble des tickets traités par le service support ne donne pas lieu à un développement. En effet, le service support a la charge de qualifier la demande du client en fonction de différents statuts.

Une revue hebdomadaire des tickets est effectuée par le responsable du service clients afin d'effectuer un état des priorités et des encours. Cette revue est effectuée pour les principaux clients.

Enfin, un comité regroupant le service clients, l'architecture fonctionnelle, la fabrication, l'exploitation et l'infrastructure permet de partager les priorités de résolution et d'intégrer d'éventuels correctifs de fond dans la feuille de route éditoriale.

Le suivi des prestataires externes

L'hébergement des données est effectué par le prestataire ECRITEL. Ce dernier loue des espaces dans deux datacenters différents localisés en France. Afin de garantir la qualité des données traitées ; Owliance vérifie avant toute entrée en relation que les hébergeurs utilisés disposent de certification d'hébergeurs de données de santé à caractère personnel. Cette liste publique est consultable sous le lien suivant :

<https://esante.gouv.fr/labels-certifications/hds/liste-des-herbergeurs-certifies>.

L'entrée en relation est ensuite formalisée par le biais d'un contrat signé composé de SLA ainsi que de clauses permettant l'audit du fournisseur.

Dans le cadre de la maîtrise des risques liés aux fournisseurs, Owliance réalise périodiquement une revue de ses principales relations afin de les classer selon les deux axes suivants :

- PSEE (Prestations de Services Essentiels Externalisées),
- Autres fournisseurs.

Pour les PSEE, le service de contrôle interne du pôle Assurances réalise un audit tous les deux ans afin de s'assurer de la correcte maîtrise des processus. La stratégie d'audit concernant les PSEE est consignée au sein de la politique d'achat groupe. La liste des PSEE peut être amenée à évoluer en fonction des différentes relations commerciales ou des nouveaux entrants.

Pour les autres fournisseurs, le risque est suivi grâce à la procédure d'achat groupe. Chaque nouveau fournisseur doit faire l'objet d'un questionnaire qui couvre les points suivants :

- RGPD,
- Sécurité de l'information,
- SAPIN II (corruption),
- Devoir de vigilance.

Cette procédure s'applique à tout achat supérieur à 5 000 €, visant :

- une entrée en relation avec un nouveau tiers ;
- un renouvellement de contrat avec un tiers historique non déjà évalué / référencé comme conforme.

La qualité passe également par la maîtrise des points abordés dans les sections suivantes.

Cas du suivi opéré sur le prestataire informatique EcriTel

Comme précisé, Owlance a souscrit des services d'hébergement pour ses serveurs auprès du prestataire informatique EcriTel. EcriTel constitue le principal prestataire de services pour les activités Edition d'Owlance.

A ce titre, les équipes Owlance opèrent un suivi de la prestation à travers les principaux contrôles suivants :

- le pilotage en continu de la prestation : un Comité de Pilotage se tient trimestriellement et regroupe les équipes du prestataire EcriTel (directeur de projets et responsable de compte) et les équipes Owlance (DSI, RSSI, Responsable ISR). Lors du comité, une revue des indicateurs contractuels est opérée afin de s'assurer du bon déroulement de la prestation et de l'atteinte des objectifs ;
- les équipes Owlance disposent sur une base mensuelle, d'un tableau de bord communiqué par EcriTel pour piloter la qualité des services. Ce tableau de bord récapitule pour le mois passé les faits marquants (incidents, actualités...), intègre des indicateurs sur la disponibilité et les performances, la sécurité, ainsi que donne une vision à travers une revue des tickets et le suivi des actions engagées sur la période.
- la revue des accès au data center : une revue annuelle des accès est opérée par les équipes Owlance et s'appuie sur les travaux de revues d'accès physiques effectués par EcriTel mensuellement ;
- la revue du rapport ISAE 3402 : EcriTel a communiqué un rapport ISAE 3402 de Type 2 couvrant la période du 1er juillet 2022 au 30 juin 2023, à destination d'Owlance en septembre 2023. Ce rapport permet ainsi à Owlance de disposer d'une vision sur l'environnement de contrôle d'EcriTel audité par un tiers indépendant.
- l'obtention des certifications d'EcriTel : à chaque renouvellement, le management d'Owlance demande et obtient de la part d'EcriTel les preuves de certifications (HDS, ISO 27001) à jour.
-

4.3. Gestion du changement

Les demandes de changement peuvent provenir des trois canaux différents suivants :

- l'intégration d'un nouveau client avec des besoins spécifiques,
- les besoins exprimés dans les cercles qualité (besoins clients ou réglementaires),
- la correction d'erreur liée à des incidents.

L'ensemble de ces demandes est enregistré via l'outil JIRA. Une qualification des demandes est effectuée par le service clients et une priorisation par le responsable de service.

Tous les changements sont d'abord détaillés lors d'une phase de présentation du projet. A l'issue de cette phase et uniquement après validation par un manager de l'équipe architecture fonctionnelle, les changements approuvés font l'objet d'une phase de développement, de

recette ou de tests, puis d'implémentation. Les étapes détaillées du processus de gestion des changements sont décrites en **Section VIII**.

En outre, les environnements de développement, de recette et de production sont bien distincts, ainsi que les utilisateurs qui y ont respectivement accès.

Ces différents contrôles/processus permettent d'éviter :

- la présence de changements non validés,
- une absence de formalisme et de traçage des changements,
- des accès non contrôlés aux environnements de développement,
- des mises en production sans test préalable.

Chaque projet suit un déroulement commun décrit dans les paragraphes ci-dessous.

Présentation du projet

Dès lors qu'un ticket client est caractérisé en « développement », l'architecture fonctionnelle a la charge de rédiger le cahier des charges en partenariat avec le client. Pour certains développements, un cahier réglementaire doit être respecté (Ex. Mise en place du 100% Santé à partir de 2019). La validation d'un manager de l'équipe architecture fonctionnelle permet de transmettre la demande aux équipes de développement.

Le développement

L'équipe de développement reçoit un besoin de l'équipe d'architecture fonctionnelle par le biais d'un ticket JIRA. L'architecture a la charge de transmettre un plan de charge partagé, les spécificités du développement ainsi que les différents jalons. L'équipe de développeurs fonctionne selon la méthode Agile.

Après réception du ticket validé, une analyse technique est réalisée et des tests croisés sont effectués avant l'organisation de sprint en collaboration avec l'équipe d'architecture. Les tests croisés sont documentés via JIRA indiquant le statut « OK » ou « KO ».

Le développement s'effectue sur un environnement indépendant de la production et de la recette.

Dès lors que la fabrication est terminée, l'équipe de développement livre un « Différentiel de version » à l'équipe de recette.

Le recette

Après réception du « Différentiel de version », un « cahier de recette » est ouvert par l'équipe de support client, indépendante de celle en charge du développement.

Le cahier des recettes peut être formalisé selon deux formats, soit par Excel soit par le biais d'un autre outil nommé « Test Link ».

L'équipe du support client a la charge d'approuver le développement par le biais de tests réalisés au sein d'un environnement de recette. Les tests effectués ainsi que les anomalies relevées sont consignés au sein de l'outil JIRA.

La fin du recettage fonctionnel est formalisée par l'émission d'un bordereau de recette reprenant l'ensemble des tests réalisés et leurs résultats.

Il est à noter que pour les déploiements de versions majeures d'Owlink, au moins un « client pilote » doit accepter de réaliser un cycle de recette. Les clients sélectionnés sont représentatifs de la population concernée par le changement. Ces tests sont également formalisés sur JIRA.

Une validation de la recette par le client permet aux équipes d'O.S.I de clôturer la phase de recette.

La mise en production

Dès lors que le développement est approuvé par les équipes de recettage et le client (pour les versions majeures), une demande de mise en production est effectuée par le biais d'un ticket JIRA.

Ce ticket de mise en production doit faire l'objet :

- D'une validation manager pour les changements mineurs,
- D'une validation manager et d'une validation client pour les changements majeurs.

Pour les clients disposant de la solution Owlink dans leurs locaux, ceux-ci ont en charge la validation du déploiement en production réalisée par les équipes d'O.S.I.

4.4. Sécurité des systèmes d'information

Plusieurs risques sont décrits dans cette section. En effet, les systèmes d'information sont soumis à diverses menaces qui peuvent être liées :

- à l'environnement extérieur (incendie des locaux, inondation, coupure d'électricité prolongée...),
- aux caractéristiques des systèmes (technologies, conception...),
- aux interventions humaines (erreur, piratage).

Ces menaces peuvent entraîner la perte ou le vol de données, l'interruption des services pendant un laps de temps, la dégradation de l'image de l'entité voire la perte de confiance des tiers dans leur fournisseur.

Pour répondre à ces différents risques, le Pôle Assurances s'est doté de différents outils permettant de faire face à ces contraintes par le biais des axes suivants :

- une organisation adaptée,
- une gestion de la sécurité logique et physique,
- la mise en place de sauvegarde,
- un plan de continuité d'activité formalisé.

Une organisation adaptée aux risques

En parallèle de la Direction des Systèmes d'Information, le Pôle Assurances a nommé un RSSI en charge d'animer le pilotage de la sécurité des systèmes d'information en coordination avec le RSSI du groupe Tessi. Une sensibilisation des collaborateurs d'Owliance Services Informatiques est réalisée par le biais de formations sur la sécurité des systèmes d'information.

SSI : Gestion de la sécurité physique et logique

La sécurité physique permet de restreindre les personnes pouvant accéder aux infrastructures hébergeant les serveurs. La gestion des accès physiques aux datacenters est déléguée à ECRITEL qui a la charge d'approuver et tracer ceux-ci par le biais de badges. Une revue périodique des accès est également effectuée par ECRITEL afin de mettre à jour le personnel habilité à accéder aux datacenters. Quant à la société O.S.I, celle-ci se trouve sur le site de MURET. L'accès du site est tracé par le biais de badges, dont un numéro est affecté à chaque salarié. Un suivi des accès est effectué par l'office manager du site et chaque départ de salarié entraîne la restitution du badge.

La sécurité logique permet de restreindre l'accès aux environnements et données sensibles, que ce soit en interne ou en externe, par le biais de piratage. Afin de contrer les éventuelles tentatives de connexion externes, le groupe TESSI déploie la solution SOPHOS Interceptis¹ sur l'ensemble des postes de travail du groupe.

Concernant les serveurs, la solution TRENDMICRO Deep Security est utilisée et supervisée par ECRITEL. Ces solutions antivirales sont régulièrement mises à jour.

Afin de réglementer les communications sur le réseau Tessi Pôle Assurances, les firewalls Sophos et Fortinet (Ecritel) sont utilisés.

En complément de ces solutions, des tests d'intrusions (a minima annuels) sont réalisés par les équipes du RSSI. Un plan d'action est ensuite mis en place afin de répondre aux éventuelles faiblesses rencontrées lors des tests.

Concernant les accès aux données, ce point est couvert par le biais d'une politique de mot de passe définie par le RSSI globalement conformes aux bonnes pratiques, notamment :

- le mot de passe doit avoir une longueur minimale de 10 caractères ;
- le mot de passe doit être composé avec une combinaison d'au moins 3 types de caractères parmi les 4 suivants : majuscules (A-Z), minuscules (a-z), chiffres (0-9) et caractères spéciaux.
- la durée de validité maximale d'un mot de passe est de 90 jours.
- les critères de verrouillage à appliquer aux comptes utilisateurs sont les suivants :
 - fixation d'un nombre maximal de tentatives d'authentification consécutives en échec (maximum 10 tentatives).
 - suspension temporaire (minimum 15 minutes) ou définitive (nécessitant une intervention d'un administrateur).
- Tout accès à un poste de travail du Pôle Assurances est protégé par le biais d'un Active Directory qui permet le changement régulier du mot de passe.
- Tout mécanisme d'authentification par mot de passe statique doit conserver au minimum l'historique des 5 derniers mots de passe créés afin d'en éviter la réutilisation.
- Les règles de composition des authentifiant de type mot de passe statique pour les comptes privilégiés doivent excéder les exigences de complexité applicables aux comptes non privilégiés.

¹ Les contrôles liés à la fiabilité/sécurisation de cette application, de même que les composants de l'environnement informatique administrés par Ecritel ou d'autres prestataires informatiques de Owliance sont exclus du périmètre du présent rapport et n'ont donc pas fait l'objet de tests spécifiques. Des contrôles de supervision seront mis en œuvre en lien avec l'obtention du rapport ISAE 3402 communiqué par Ecritel.

L'accès à l'application Owlink par un client est également protégé par un mot de passe et un identifiant :

- de connexions à distance sécurisées et cryptées via l'usage combiné du VPN Fortinet et d'un système d'authentification forte.
- d'une limitation des comptes administrateurs qui sont actuellement restreints aux équipes adéquates (sécurité, infrastructure...). Ces comptes sont nominatifs et les logs peuvent être exploités. Toute nouvelle création, modification ou suppression de comptes utilisateurs doit être validée par le biais de l'outil de ticketing. Les profils attribués aux collaborateurs sont en adéquation avec la fonction occupée.
- d'une revue annuelle des personnes habilitées à consulter les données liées à l'application Owlink. Cette revue s'effectue par l'obtention d'une liste transmise par le service des ressources humaines.
- d'une cybersurveillance par le biais de bulletins hebdomadaires auprès de CERT XMCO.

Enfin, l'ensemble des communications entre O.S.I et les clients sur Internet sont sécurisées par le biais d'un protocole SSL et d'une clé de cryptage de 2048 bits.

4.5. Gestion et suivi de l'exploitation

Afin de garantir une continuité d'accès à la plateforme SaaS Owlink, des contrôles récurrents sont effectués de manière adéquate et en temps opportun.

Gestion et organisation de l'exploitation

L'équipe Exploitation détermine à chaque début de mois, un plan de production incluant la totalité des traitements. Le suivi des tâches effectuées est matérialisé par le biais d'une feuille route (description dans le paragraphe suivant) mise à jour quotidiennement.

Suivi de l'exploitation

Afin de garantir un niveau de service satisfaisant aux clients d'Owlink, l'environnement de production est surveillé de manière continue dans le but d'identifier les problèmes relatifs à la disponibilité du service ou au temps de réponse. A partir de ce suivi, Tessi Pôle Assurances souhaite corriger rapidement les dysfonctionnements susceptibles d'impacter les clients infogérés.

Pour répondre à ce risque d'anomalie, Tessi Pôle Assurances dispose de deux outils. Le premier est une feuille de route développée sur Excel qui permet de centraliser l'ensemble des actions mensuelles à réaliser par client. Ces points sont définis en amont et concernent des opérations clés comme l'envoi de données en banque, l'incorporation des données Noémie, le traitement des flux de tiers payant ou des points spécifiques au portefeuille infogéré. Ce fichier peut en effet être enrichi au fil du temps par le biais d'anciens problèmes rencontrés.

En parallèle, un second outil du marché nommé « Control-M² », permet d'ordonnancer et de lancer les traitements complémentaires entièrement automatisés. Pour rappel, chaque client

² Edité par BMC Software

dispose d'un environnement propre permettant de séparer les données de chaque entité. Control-M permet de lancer un script sur les différents environnements et d'identifier les dysfonctionnements.

Le statut des traitements (« En cours », « Terminé », « Anomalie ») est consultable au sein d'un menu spécifique d'Owlink. Pour les traitements en anomalie, ceux-ci sont retranscrits chaque matin au sein d'un courriel automatique envoyé au service d'exploitation.

Concernant les anomalies, une première analyse est effectuée afin de définir le niveau de criticité de celle-ci. Si l'analyse nécessite un développement ou la modification d'un traitement automatique, un ticket JIRA sera créé. Les modifications de scripts sont revues et approuvées par les managers avant mise en production.

En complément de ce monitoring, des scans de vulnérabilité sont réalisés trimestriellement et les éventuelles actions de remédiation sont documentées.

Processus de revue périodique

Tous les ans, une revue des habilitations, des profils et des comptes privilégiés est réalisée par des responsables habilités pour chaque périmètre client. Les modifications demandées sont tracées, et effectuées au plus tard en fin de mois.

Afin de garantir une plus grande confidentialité des données, chaque client dispose de son propre environnement informatique.

Gestion de la sauvegarde

Afin de pallier les éventuelles pertes de données engendrées par un incident technique, des sauvegardes externes quotidiennes des bases de données Owlink sont effectuées par l'équipe Exploitation. Les statuts des sauvegardes sont vérifiés par l'Exploitation. En cas d'erreur de sauvegarde, un ticket est généré afin de tracer les investigations et la résolution des problèmes soulevés. L'hébergeur s'appuie sur la solution Veeam Backup.

Un test de restauration est réalisé de manière annuelle par l'hébergeur sous supervision du RSSI. En cas de défaillance, un plan d'action est rapidement mis en place afin de corriger les erreurs relevées.

Le Plan de Continuité d'Activité et les tests de reprises

Afin de remédier à toute indisponibilité, les structures Owliance disposent d'un plan de continuité d'activité.

Il existe un plan spécifique à chaque site de gestion. Le PCA du site de Muret intègre également l'activité d'édition. Le détail du plan de continuité d'activité couvrant les prestations liées à l'édition du logiciel.

Owlink est décrit en **section VIII** (section du rapport non couverte par l'opinion de l'auditeur indépendant et communiquée uniquement pour information). Des tests concernant le PCA sont effectués à minima une fois par an.

5. CONTROLES COMPLEMENTAIRES PAR LES UTILISATEURS DU RAPPORT

Les contrôles décrits par Owlance ne constituent qu'une partie de l'environnement de contrôle global relatif à la prestation de services délivrée par Owlance à travers la mise à disposition du progiciel OwlLink en mode SaaS. À cet égard, les Clients doivent mettre en place et maintenir un dispositif de contrôle efficace et qui prévoit entre autres que :

- les instructions et informations transmises à Owlance par ses Clients doivent être en conformité avec les clauses prévues au contrat ;
- la liste des personnes habilitées à donner des instructions à Owlance ou ayant accès aux applicatifs Owlance est régulièrement mise à jour et transmise à Owlance.

Afin d'apprécier si les objectifs de contrôle sont atteints, il est de la responsabilité de l'organisme utilisateur de s'assurer que les contrôles complémentaires suivants sont mis en œuvre et maintenus au sein de son organisation :

Thématique	Activité de contrôle attendue au sein de l'organisme utilisateur du rapport
Formation des clients	Les clients ont la responsabilité d'identifier les personnes au sein de leur organisation qui devraient recevoir une formation sur l'application «Owlink by Tessi» et de s'assurer que : ▪ ces personnes ont reçu une formation sur l'application ▪ seulement les utilisateurs qui ont reçu une formation appropriée utilisent l'application «Owlink by Tessi».
Configuration des clients	Les clients sont responsables de la désactivation ou de la suppression des utilisateurs qui n'ont plus besoin d'accès à l'application après configuration du compte de l'entité utilisatrice.
Gestion des accès	▪ Les clients ont la responsabilité de s'assurer que les comptes de type « administrateur » sont configurés comme demandé. ▪ Il appartient aux clients de notifier par écrit à Owlance les demandes de mises à jour des comptes administrateur (par exemple, changement de mot de passe ou changement d'administrateur...). ▪ Les clients accordent et révoquent l'accès des utilisateurs à leur environnement « Owlance by Tessi », sous leur seule responsabilité (par exemple collaborateurs ou sous-traitants) ▪ Les clients ont la responsabilité de s'assurer que seuls les utilisateurs autorisés par leurs soins ont accès à leur environnement de production.
Mécanismes d'authentification	▪ Une configuration des mots de passe par défaut est appliquée lors de la mise à disposition de l'application OwlLink auprès de l'entité utilisatrice. Toutefois, il appartient aux entités utilisatrices de configurer la stratégie de mot de passe appliquée dans leur environnement de production conformément à leur politique interne sécurité (longueur minimale, nombre de caractères, durée de vie du mot de passe...).

		Les entités utilisatrices sont également responsables de la confidentialité et des actions effectuées via ces identifiants.
Autorisation des transactions		Les clients sont responsables de l'implémentation d'un workflow de double validation des paiements (4 yeux) : Validation des données d'administration : sociétés, comptes, bénéficiaire, utilisateurs via la mise à disposition d'un workflow pour valider les remises.
Traçabilité des activités		Les clients sont responsables de la décision d'implémenter ou non un examen des journaux relatifs aux transactions financières effectuées via l'application « Owlance by Tessi » (en cas d'activation des logs à leur demande).
Connectivité de l'entité utilisatrice à l'application « Owlance by Tessi »		- Les clients sont responsables de la mise en place de la sécurité logique et physique des stations de travail utilisées pour se connecter à l'application « Owlance by Tessi ». - Les clients sont responsables de la protection des stations de travail avec des antivirus ou anti-malware.
Continuité des opérations		Les clients sont responsables de maintenir des plans de continuité d'activité qui fournissent une connectivité à l'application « Owlance by Tessi » en cas de perturbation dans l'environnement du client.

6. PERIMETRE DU RAPPORT

Le présent rapport s'applique à l'activité d'édition du pôle Tessi Assurances et plus particulièrement à la solution «Owlink by Tessi» dans sa version SaaS.

Gérée par une entité à part, Owlance Services Informatiques conçoit, développe et livre des versions adaptées aux besoins des clients et à la réglementation.

Quant à l'activité d'hébergement externalisée auprès de la société Eritel, celle-ci étant couverte par un rapport ISAE 3402 qui lui est propre, les contrôles relatifs à la sécurité physique et protections environnementales ne sont pas intégrés dans le présent rapport en vertu d'une approche dite de carve-out.

La Direction de Tessi Assurances est responsable :

- Des objectifs associés,
- De la définition des points de contrôle,
- Des contrôles manuels et automatisés mis en place pour atteindre ses objectifs.



SECTION VI : OBJECTIFS DE CONTROLE

Les informations génériques et les critères de contrôle suivants ont été utilisés pour préparer le système global et la description des processus, afin de déterminer si les contrôles ont été conçus de manière appropriée et fonctionnent réellement.

Ces critères sont inspirés des référentiels de bonnes pratiques internationales de contrôle COBIT (Control Objectives for Information and related Technology, en français Objectifs de contrôle de l'Information et des Technologies Associées) et COSO (référentiel de contrôle interne défini par le Committee Of Sponsoring Organizations of the Treadway Commission), et sont basés sur les exigences juridiques et métier liées à la gestion des services offerts par la société Owlance Services Informatiques:

- Confidentialité : concerne la protection des données sensibles contre toute divulgation non autorisée.
- Intégrité : concerne l'exactitude et l'exhaustivité des données ainsi que leur validité conformément aux valeurs et aux attentes métier.
- Disponibilité : relatif à la disponibilité des données et systèmes lorsque requis par le processus métier, maintenant et à l'avenir ; concerne également la protection des ressources nécessaires et des capacités associées.
- Efficacité :
 - Concerne la pertinence des données pour les processus métier, et leur livraison de manière opportune, correcte, cohérente et utilisable,
 - Concerne la fourniture des données par une utilisation optimale des ressources (la plus productive et économique).

Dans cette partie, sont présentés les objectifs de contrôle tels que **définis par la société Owlance** et considérés comme nécessaires pour ses Clients et leurs auditeurs. Y sont associés les contrôles mis en place pour atteindre ces objectifs.

Thématique	#	Objectifs de contrôle
Gestion des changements	1	Les contrôles fournissent une assurance raisonnable que les modifications liées à la plateforme SaaS Owlance, au réseau, au serveur et aux structures de base de données sont autorisées, testées et approuvées par la direction et mises en œuvre de manière complète, précise et en temps opportun.
Sécurité logique	2	Les contrôles fournissent une assurance raisonnable que l'accès logique à la plateforme SaaS Owlance, aux données et aux ressources informatiques est limité aux utilisateurs autorisés et appropriés.
Gestion de l'exploitation	3	Les contrôles fournissent une assurance raisonnable que les outils sécurisant le réseau sont mis en œuvre, configurés, administrés et surveillés pour restreindre l'accès à la plateforme SaaS Owlance, aux données et aux autres ressources d'information.
	4	Les contrôles fournissent une assurance raisonnable que la surveillance de la plateforme SaaS Owlance est effectuée de manière adéquate et conduit à des actions appropriées et en temps opportun.
	5	Les contrôles fournissent une assurance raisonnable que les traitements automatiques des systèmes supportant la plateforme SaaS Owlance sont autorisés et exécutés sans erreurs,

Thématique	#	Objectifs de contrôle
		et en temps opportun, et que les problèmes et erreurs identifiés, sont suivis, enregistrés et résolus en temps opportun.
	6	Les contrôles fournissent une assurance raisonnable que les données de la plateforme OwlLink sont sauvegardées, conservées et peuvent être restaurées pour éviter la perte d'informations clés.
Sécurité physique	7	Les contrôles fournissent une assurance raisonnable que les infrastructures informatiques sont correctement sécurisées et protégées contre les risques environnementaux et que l'accès aux locaux des centres de données est correctement limité au personnel approprié.
Relation client	8	Les contrôles fournissent une assurance raisonnable que les demandes de renseignements ou les demandes urgentes par ses clients sont gérées de manière adéquate et en temps opportun.
Gestion des fournisseurs	9	Les contrôles fournissent une assurance raisonnable que les relations entre Tessi France et ses prestataires de services sont correctement gérées et surveillées en temps opportun.

SECTION VII :
**OBJECTIFS DE
CONTROLE,
CONTROLES CLES
ET TESTS
D'EFFICACITE
OPERATIONNELLE**

Les résultats des tests réalisés sur la base des contrôles décrits, mis en place et effectués par Owlance sont présentés ci-après. Les tests réalisés ainsi que leurs résultats sont de la responsabilité de l'auditeur indépendant.

1. GESTION DES CHANGEMENTS

Objectif de contrôle #1			
Les contrôles fournissent une assurance raisonnable que les modifications liées à la plateforme SaaS Owlance, au réseau, au serveur et aux structures de base de données sont autorisées, testées et approuvées par la direction et mises en œuvre de manière complète, précise et en temps opportun.			
Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
CM1	Les demandes de changements liées au logiciel Owlance sont créées et tracées via un outil de ticketing. Chaque demande doit être approuvée par un manager de l'équipe architecture fonctionnelle en amont du développement.	Inspection Inspecter, sur la base d'un échantillon de changements, que les demandes de changements ont été effectuées dans un système de ticketing et approuvées pour développement par l'équipe produit.	Aucun écart identifié
CM2	Des tests croisés de validation sont effectués par les équipes de développement pour identifier les potentielles anomalies durant la phase de développement. Les défauts identifiés sont réassignés à l'équipe de développement et traités pour intégration dans les packages ultérieurs.	Inspection Inspecter, sur la base d'un échantillon de changements implémentés dans l'environnement de production, que des tests d'acceptation ont été effectués, et que les défauts constatés ont été traités par l'équipe de développement pour prise en compte dans le package suivant livré en production.	Aucun écart identifié
CM3	Des environnements distincts de production et de développement sont implémentés.	Inspection Inspecter l'existence d'un environnement de développement et d'un environnement de test pour l'application Owlance et que ces environnements sont séparés de l'environnement de production.	Aucun écart identifié
CM4	Des tests sont réalisés en environnement de test par une équipe dédiée à la recette fonctionnelle. Ces derniers sont tracés et documentés via un outil de ticketing. Un bordereau de recette	Inspection Inspecter sur la base d'un échantillon de changements, que des tests ont été effectués par l'équipe produit dans un	Aucun écart identifié

	faisant office d'approbation et de fin de la phase de test est ensuite émis. Dans le cadre des déploiements de versions majeures, des tests utilisateurs sont également réalisés par le client avant déploiement en production. Une validation de la recette client est ensuite transmise à Owlance.	environnement de test dédié, que des tests d'acceptation par l'utilisateur ont été effectués et obtenus pour une évolution majeure.	
CM5	Une fois la phase de test effectuée, les changements liés au logiciel Owlance sont approuvés par un manager approprié avant déploiement en environnement de production. Dans le cadre des déploiements de versions majeures, une approbation client est donnée en amont du déploiement en environnement de production. Cette approbation est tracée via un ticket JIRA dédié.	Inspection Inspecter sur la base d'un échantillon de changement que les tickets indiquent que les changements ont été approuvés pour déploiement en environnement de production par l'équipe Exploitation.	Aucun écart identifié
CM6	Des notifications sont envoyées par mail aux clients afin de les informer des mises à jour/déploiements majeurs.	Inspection Inspecter, sur la base d'un échantillon d'évolutions majeures sur l'application Owlance, que pour chacune des occurrences, une notification a été envoyée aux clients afin de s'assurer que ceux-ci étaient informés de la mise à jour prévue et de l'impact potentiel sur le service.	Aucun écart identifié
CM7	Les membres des équipes de développement ne disposent pas d'accès à l'environnement de production, à l'exception des équipes de maintenance applicative conformément à la politique en vigueur.	Inspection Inspecter que les accès utilisateurs à l'environnement de production sont limités au seul personnel de l'équipe d'exploitation.	Aucun écart identifié
CM8	Un processus de gestion de la bibliothèque de codes source est en place afin de gérer les codes source des différents environnements. L'accès à la bibliothèque de codes source est restreint au personnel approprié en fonction de leur poste.	Inspection Inspecter que les modifications apportées au code source sont enregistrées, que les versions antérieures sont conservées et que l'accès à la bibliothèque du code source est correctement accordé aux seuls membres de l'équipe de développement.	Aucun écart identifié

CM9	Les changements techniques relatifs à l'infrastructure (OS, patches, changements de configuration) sont tracés, testés (si applicable) et approuvés par un référent approprié avant déploiement.	Inspection Inspecter sur la base d'un échantillon de changements relatifs à l'infrastructure, la documentation garantissant que l'approbation a été accordée par la Direction OSI avant la mise en œuvre de chaque changement.	Aucun écart identifié
CM10	Un processus est en place afin de permettre aux développeurs de l'équipe maintenance d'accéder à l'environnement de production en cas d'urgence. De tels accès sont tracés, approuvés et suivis.	Inspection Inspecter, sur la base d'un échantillon de demandes en urgence que les développeurs, après approbation du client, se sont vu accorder des accès à des répliques anonymisées de leurs environnements de production pour résoudre les problèmes.	Aucun écart identifié
CM11	Les changements urgents sont suivis via l'outil de ticketing. Chaque changement urgent doit être approuvé par un manager approprié. L'approbation doit être documentée dans le ticket avant ou après déploiement en production en fonction du degré d'urgence.	Inspection Inspecter sur la base d'un échantillon de changements urgents, que les demandes de changements ont été soumises formellement dans des tickets, et que les changements effectués ont été testés et approuvés par la direction avant leur mise en œuvre.	Aucun écart identifié

2. SECURITE LOGIQUE

Objectif de contrôle #2			
Les contrôles fournissent une assurance raisonnable que l'accès logique à la plateforme SaaS OwlLink, aux données et aux ressources informatiques est limité aux utilisateurs autorisés et appropriés.			
Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
LS1	Les clients ayant accès à OwlLink sont identifiés sur l'application via des identifiants utilisateurs uniques. Les données stockées dans les bases de données sous-jacentes ne sont accessibles que via un identifiant unique afin de restreindre l'accès aux personnes appropriées uniquement.	Inspection Inspecter au niveau de la base de données supportant l'application OwlLink que toutes les données étaient affectées à un identifiant unique existant pour chaque client afin de restreindre l'accès aux utilisateurs autorisés du client.	Aucun écart identifié
LS2	Un logiciel antivirus est installé sur chaque serveur OwlLink. Ce dernier est mis à jour de manière régulière, et les alertes remontées sont suivies.	Inspection Inspecter qu'une solution antivirus était installée sur les postes de travail et les serveurs d'OwlLink. Inspection Inspecter que la solution antivirus a fait l'objet de mise à jour automatique à la date de notre intervention et que pour une alerte identifiée, la mise à jour a été effectuée dans un délai raisonnable.	Aucun écart identifié Aucun écart identifié
LS3	La configuration des mots de passe définie par Tessi permet l'application de critères de complexité conformes aux bonnes pratiques : ▪ longueur minimale, ▪ historique de mots de passe, ▪ caractères spéciaux, ▪ durée d'expiration. Les mots de passe des comptes par défaut sont modifiés par l'administrateur système lors de l'installation. Les utilisateurs ont un identifiant unique permettant de les identifier facilement et de retracer leurs actions.	Inspection Inspecter que pour la configuration des mots de passe de l'application OwlLink, ces mots de passe ont été configurés pour répondre aux exigences établies par OwlLink. Inspection Inspecter que l'accès au réseau était limité aux utilisateurs autorisés par des mots de passe et que les mots de passe des utilisateurs devaient répondre aux exigences établies.	Aucun écart identifié Aucun écart identifié

LS4	Lors de l'arrivée d'un nouveau collaborateur, l'accès au réseau de Tessi, au VPN ainsi qu'aux applications est fourni par l'équipe Support en accord avec la demande réalisée et le poste du collaborateur concerné. La demande d'accès est tracée via un outil de ticketing, et doit être approuvée par un manager approprié avant mise à disposition desdits accès.	Inspection Inspecter sur la base d'un échantillon d'employé nouvellement embauché, que l'accès au réseau/VPN et aux applications de ces derniers étaient activés conformément aux responsabilités professionnelles assignées et à l'approbation du manager hiérarchique.	Aucun écart identifié
LS5	Lors de la mobilité d'un collaborateur, l'accès au réseau de Tessi, au VPN ainsi qu'aux applications est mis à jour par l'équipe Support en accord avec la demande réalisée et le poste du collaborateur concerné. La demande de modification est tracée via un outil de ticketing, et doit être approuvée par un manager approprié avant mise à disposition desdits accès.	Inspection Inspecter sur la base d'un échantillon d'employés ayant bénéficié d'une mobilité, que pour chacun de ces employés, un ticket a été créé formalisant les droits au réseau/VPN et aux applications à mettre à jour conformément aux responsabilités professionnelles attribuées et à l'approbation du manager hiérarchique. Inspecter également que les accès ont été restreints conformément au ticket émis.	Aucun écart identifié
LS6	Lors du départ d'un collaborateur, ses accès au réseau Tessi, aux applications et au VPN sont désactivés par l'équipe Support. La désactivation est tracée via un outil de ticketing.	Inspection Inspecter sur la base d'un échantillon d'employés sortis des effectifs au cours de la période sous revue que pour chacun de ces employés, une demande de suppression des accès utilisateurs pour les accès au réseau/VPN et aux applications et que ses accès avaient bien été supprimés au moment de notre intervention.	Aucun écart identifié
LS7	Annuellement, les comptes réseau et applicatifs Owlance sont revus par des managers appropriés afin de s'assurer de leur correcte attribution. À la suite de la revue, les accès sont mis à jour conformément aux modifications identifiées.	Inspection Inspecter sur la base d'un échantillon d'accès réseau et applicatifs qu'une revue des accès réseau et applicatifs est effectuée et que les besoins de modifications identifiés ont été ensuite mis à jour.	Aucun écart identifié

LS8	L'Active Directory est configurée de sorte à permettre un contrôle renforcé des mots de passe. Les employés doivent modifier leur mot de passe lors de leur première connexion. Les mots de passe doivent être modifiés de manière régulière.	Inspection Inspecter que le réseau était limité aux utilisateurs autorisés par des mots de passe et que les mots de passe des utilisateurs devaient répondre aux exigences établies.	Aucun écart identifié
LS9	Une politique de mot de passe est formalisée afin d'assurer que les mots de passe en place sont conformes aux bonnes pratiques et suffisamment robustes.	Inspection Inspecter que la politique de mot de passe informatique est établie et vérifier qu'elle fait référence à des paramètres conformes aux bonnes pratiques.	Aucun écart identifié
LS10	Les accès à distance du personnel au réseau Tessi sont cryptés via l'usage combiné d'un VPN et d'un système d'authentification forte	Inspection Inspecter que l'accès à distance au réseau Owlance à l'aide d'un VPN était crypté et reposait sur une authentification à deux facteurs.	Aucun écart identifié
LS11	L'attribution de comptes administrateurs est restreint à un nombre minimal d'utilisateurs appropriés.	Inspection Inspecter que les comptes privilégiés étaient réservés aux équipes exploitation, infrastructure et sécurité.	Aucun écart identifié
LS12	Une formation obligatoire à la sécurité des systèmes d'information doit être suivie pour tout nouvel arrivant. Un suivi mensuel est effectué pour s'assurer du correct suivi de ces formations, et des relances sont envoyées aux personnes non formées.	Inspection Inspecter qu'un suivi de la formation obligatoire à la sécurité des systèmes d'information est correctement réalisée et que des relances sont envoyées aux personnes n'ayant pas encore suivi la formation.	Aucun écart identifié

3. GESTION DE L'EXPLOITATION

Objectif de contrôle #3			
Les contrôles fournissent une assurance raisonnable que les outils sécurisant le réseau sont mis en œuvre, configurés, administrés et surveillés pour restreindre l'accès à la plateforme SaaS Owlink, aux données et aux autres ressources d'information.			
Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
CO1	La communication entre Owlink et les clients sur internet est sécurisée par l'utilisation d'un protocole SSL. La clé de cryptage est de 2048 bits.	Inspection Inspecter que la communication entre Owlink et les clients sur internet est sécurisée par l'utilisation d'un protocole SSL	Aucun écart identifié
CO2	Des pare-feux et des systèmes IDS/IPS sont installés et configurés pour empêcher des accès non autorisés aux réseaux et aux applications Owliance.	Inspection Inspecter que des pare-feux et des systèmes IDS/IPS sont installés et configurés pour empêcher des accès non autorisés aux réseaux et aux applications Owliance.	Aucun écart identifié
CO3	Des tests d'intrusion interne et externe sont réalisés de manière annuelle. Les points faibles identifiés font l'objet d'un plan d'action afin de suivre et d'assurer la correcte remédiation des failles identifiées.	Inspection Inspecter que les tests d'intrusion interne et externe sont réalisés de manière annuelle.	Aucun écart identifié
		Inspection Inspecter que les points faibles identifiés font l'objet d'un plan d'action afin de suivre et d'assurer la correcte remédiation des failles identifiées.	Aucun écart identifié

Objectif de contrôle #4

Les contrôles fournissent une assurance raisonnable que la surveillance de la plateforme SaaS OwlLink est effectuée de manière adéquate et conduit à des actions appropriées et en temps opportun.

Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
CO4	Owliance surveille de manière continue l'environnement de production OwlLink afin d'identifier les problèmes relatifs à la disponibilité du service ou au temps de réponse. Les incidents identifiés sont suivis via un outil de ticketing jusqu'à résolution desdits incidents. Les étapes de résolution sont documentées.	Inspection Sur la base d'un échantillon d'alertes d'indisponibilité du système, inspecter les détails de l'alerte pour s'assurer que les alertes ont été examinées et résolues par l'équipe d'exécution en temps opportun.	Aucun écart identifié
CO5	Des scans de vulnérabilité sont effectués de manière trimestrielle, et des actions de remédiation sont mises en place et suivies en cas d'incident.	Inspection Sur la base d'un échantillon d'un échantillon de scans de vulnérabilité, inspecter que ces derniers sont correctement réalisés, que des plans de remédiation sont mis en place ainsi que des suivis en cas d'incident.	Aucun écart identifié
CO6	Une veille est effectuée à partir des communications des fournisseurs de services (logiciels, infrastructure) ou de bulletins de sécurité dédiés. En cas d'identification de vulnérabilité, des correctifs système sont mis en place afin de corriger ces dernières.	Inspection Inspecter qu'une veille est effectuée à partir des communications des fournisseurs de services (logiciels, infrastructure) ou de bulletins de sécurité dédiés. Inspection Inspecter que des correctifs sont mis en place en cas d'identification de vulnérabilité système.	Aucun écart identifié Aucun écart identifié
CO7	Les incidents de sécurité sont enregistrés et suivis dans un outil de ticketing. Tout incident suit un processus formel de résolution (identification, escalade, résolution).	Inspection Inspecter sur la base d'un échantillon d'incidents de sécurité que ces derniers sont tracés dans un outil de ticketing.	Aucun écart identifié

	L'ensemble des étapes et des preuves de résolution sont documentées dans le ticket d'incident. Ce dernier est résolu dans un délai raisonnable.	Inspection Inspecter que le processus de résolution est formalisé à travers des preuves de résolution documentées et dans un temps de résolution acceptable.	Aucun écart identifié
--	---	--	-----------------------

Objectif de contrôle #5

Les contrôles fournissent une assurance raisonnable que les traitements automatiques des systèmes supportant la plateforme SaaS OwlLink sont autorisés et exécutés sans erreurs, et en temps opportun, et que les problèmes et erreurs identifiés, sont suivis, enregistrés et résolus en temps opportun.

Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
CO8	Les modifications relatives aux traitements automatiques / scripts sont revues et approuvées par des managers appropriés avant déploiement en production. L'accès à l'ordonnanceur est restreint au personnel de l'équipe d'exploitation informatique.	Inspection Inspecter sur la base d'un échantillon que les modifications relatives aux traitements automatiques / scripts sont revues et approuvées par les responsables Exploitation ou Infrastructure avant d'être mises en œuvre en environnement de production.	Aucun écart identifié
		Inspection Inspecter que l'accès était correctement limité au personnel autorisé de l'équipe d'exploitation.	Aucun écart identifié
CO9	L'état des traitements automatiques est suivi par l'équipe d'exploitation OwlLink de manière quotidienne, en accord avec le plan d'exploitation défini mensuellement. En cas d'erreurs de traitement, ces dernières sont tracées via un ticket, investiguées et résolues par les équipes dédiées.	Inspection Inspecter dans le planificateur de tâches les paramètres configurés pour informer automatiquement l'équipe Exploitation des interruptions de tâches. Inspection Inspecter le traçage de toute erreur de traitement identifiée de manière quotidienne, et que des actions correctives avaient été mises en place.	Aucun écart identifié Ecart identifié D1: Incapacité à mener à bien le test en l'absence d'obtention des preuves demandées

			pour un échantillon de 20 incidents de traitements sélectionnés.
--	--	--	--

Objectif de contrôle #6

Les contrôles fournissent une assurance raisonnable que les données de la plateforme OwlLink sont sauvegardées, conservées et peuvent être restaurées pour éviter la perte d'informations clés.

Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
CO10	Des sauvegardes incrémentales de la plateforme OwlLink et des bases de données sont effectuées de manière quotidienne. Tous les jours, l'équipe exploitation vérifie les statuts des sauvegardes afin de s'assurer de leur correcte exécution. En cas d'erreur, un ticket est créé et ces dernières sont investiguées et résolues dans un délai raisonnable.	Inspection Inspecter pour des dates échantillonnées, que les sauvegardes ont été effectuées selon les modalités attendues.	Ecart identifié D2 : Nous n'avons pas pu obtenir de preuves de sauvegarde pour 15 dates sur un échantillon total de 25 dates sélectionnées.
CO11	Tous les ans, un test de restauration est effectué. En fonction des résultats, un plan d'actions est défini et suivi.	Inspection Inspecter sur la base d'un échantillon de test de restauration, que ces derniers sont bien réalisés selon la fréquence définie, qu'un plan d'action a bien été formalisé et suivi.	Aucun écart identifié

4. SECURITE PHYSIQUE

Objectif de contrôle #7			
Les contrôles fournissent une assurance raisonnable que les infrastructures informatiques sont correctement sécurisées et protégées contre les risques environnementaux et que l'accès aux locaux des centres de données est correctement limité au personnel approprié.			
Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
PS1	L'accès physique aux datacenters est restreint à un nombre limité de personnes appropriées (fournisseurs etc.).	Inspection Inspecter que l'accès conféré était limité aux cadres supérieurs et aux membres de l'équipe de développement.	Aucun écart identifié
	Les accès physiques sont tracés et approuvés par des référents appropriés en amont de leur attribution.	Inspection Inspecter que le registre des accès aux datacenters à la date de notre intervention était limité aux équipes de développement.	Aucun écart identifié
PS2	De manière mensuelle, une revue des accès physiques aux datacenters est effectuée par Ecritel.	Inspection Inspecter que les droits d'accès sont mis à jour si nécessaire sur la base d'un échantillon des résultats de la revue effectuée par Ecritel.	Aucun écart identifié
	À la suite de la revue, la liste des accès est mise à jour en fonction des changements identifiés.	Inspection Inspecter qu'Owliance effectue une revue du contrôle effectué par Ecritel tel que décrit.	Aucun écart identifié
PS3	Les accès physiques aux datacenters hébergeant l'infrastructure Owliance sont limités au personnel autorisé via l'usage de badges d'accès.	Inspection Inspecter que les accès physiques aux datacenters hébergeant l'infrastructure Owliance sont limités au personnel autorisé via l'usage de badges d'accès.	Aucun écart identifié
	Les locaux disposent de dispositifs permettant d'alerter des référents appropriés en cas d'intrusion (dispositif de vidéo-surveillance, alarmes etc.)	Inspection Inspecter que les locaux disposent de dispositifs permettant d'alerter des référents appropriés en cas d'intrusion.	Aucun écart identifié

5. RELATION CLIENT

Objectif de contrôle #8			
Les contrôles fournissent une assurance raisonnable que les demandes de renseignements ou les demandes urgentes par ses clients sont gérées de manière adéquate et en temps opportun.			
Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
CS1	Tous les jours, le service client reçoit les demandes client via différents canaux (internet, téléphone, mail), et les reporte dans l'outil de ticketing (JIRA).	Inspection Inspecter que les représentants du service clientèle reçoivent les demandes des clients et les reportent dans l'outil de ticketing.	Aucun écart identifié
	Le service client traite les demandes jusqu'à leur résolution, qui est tracée et documentée via un ticket.	Inspection Inspecter sur la base d'un échantillon de demandes client, que ces dernières sont suivies dans un outil de ticketing jusqu'à leur résolution.	
CS2	De manière mensuelle, l'équipe "Service Client" revoit les demandes des principaux clients afin de s'assurer que ces dernières sont résolues et traitées dans un délai raisonnable.	Inspection Inspecter sur la base d'un échantillon de demandes client remontées que ces dernières sont examinées et qu'elles sont traitées dans un délai raisonnable selon le niveau de criticité qu'il leur est affecté.	Aucun écart identifié

6. GESTION DES FOURNISSEURS

Objectif de contrôle #9			
Les contrôles fournissent une assurance raisonnable que les relations entre Tessi France et ses prestataires de services sont correctement gérées et surveillées en temps opportun.			
Ref. Ctrl	Description du contrôle	Procédures de test	Conclusion
VM1	Des contrats formels sont signés entre Owlance et les fournisseurs critiques ayant un impact sur les niveaux de service de la plateforme Owlinc. Ces contrats sont archivés par Tessi. Une liste des fournisseurs critiques est maintenue par Tessi.	Inspection Inspecter qu'un contrat existait avec le fournisseur de services Eritel pour les services de colocation au niveau du data center hébergeant les serveurs Owlance. Inspecter également que ce contrat avait été signé par les deux parties et archivé.	Aucun écart identifié
VM2	Tous les mois, des comités de pilotage sont organisés entre Owlance et ses fournisseurs critiques afin de piloter l'activité de ces derniers, et de s'assurer que les indicateurs définis dans les contrats sont bien suivis et que les objectifs sont bien atteints.	Inspection Inspecter sur la base d'un échantillon de comité de pilotage entre Owlance et ses fournisseurs critiques, que ces derniers étaient bien organisés Inspection Inspecter sur la même base d'échantillonnage que les indicateurs définis dans les contrats étaient bien suivis lors du Comité de Pilotage.	Aucun écart identifié Aucun écart identifié
VM3	Tous les ans, une revue des rapports ISAE 3402 des prestataires essentiels d'Owlance est effectuée, incluant une analyse des contrôles en place chez lesdits prestataires afin de s'assurer que les risques définis par Owlance sont bien couverts.	Inspection Inspecter qu'une revue des rapports ISAE 3402 des prestataires essentiels d'Owlance avait été effectuée par Owlance, incluant une analyse des contrôles mis en place.	Aucun écart identifié

SECTION VIII :
AUTRES
INFORMATIONS
FOURNIES PAR
OWLIANCE ET
NON
COUVERTES
PAR L'OPINION
DE L'AUDITEUR
INDEPENDANT

Dispositif de mise en conformité vis-à-vis du RGPD

Afin de garantir une mise en conformité au Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016, le groupe TESSI a mis en place un plan d'action applicable à l'ensemble des entités du groupe.

Ce plan d'action comprend la mise en place :

- D'une politique de protection des données à caractère personnel,
- De clauses contractuelles sur la protection des données,
- D'un registre des traitements,
- D'une procédure de conservation des données personnelles,
- D'une procédure d'exercice des droits des personnes,
- D'un Data Protection Officer (DPO) au sein de chaque entité,
- De relais DPO,
- Du principe de Privacy By Design et Privacy By Default. Ce principe implique que l'ensemble des nouveaux produits doit prévoir les durées de conservation de données à caractère personnel,
- D'un plan de formation et de sensibilisation des salariés à la RGPD.

Le DPO groupe a pour principale responsabilité de veiller à ce que les entités de Tessi respectent la présente politique et les réglementations en vigueur en matière de protection des données.

Il a la charge de :

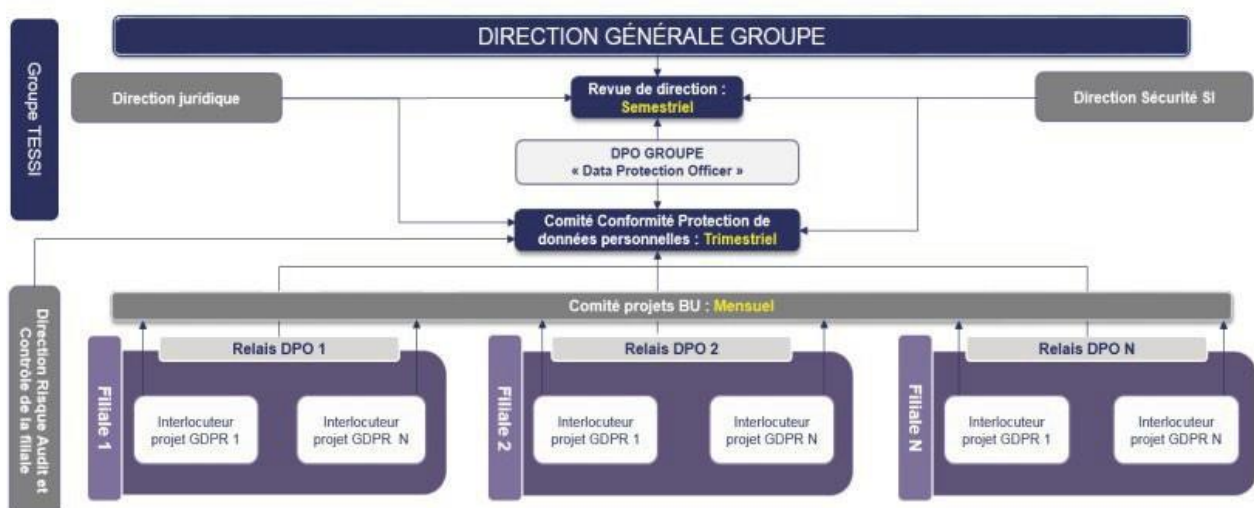
- Définir la politique générale de protection des données du groupe, les procédures à respecter et les règles de contrôle à mettre en place pour une protection efficace des données à caractère personnel des collaborateurs et des clients.
- Informer, conseiller et prendre toutes les mesures nécessaires envers les sous-traitants du groupe afin qu'ils garantissent eux-mêmes la conformité à la réglementation en vigueur concernant les traitements de données à caractère personnel qui leur sont confiés ;
- Informer régulièrement la direction générale de l'état de la Politique de Protection des Données Personnelles ;
- Répondre aux demandes et aux plaintes présentées par les employés, les clients et d'autres tiers bénéficiaires, évaluer la collecte et l'utilisation des données à caractère personnel par les entités du groupe en termes de risques liés à la protection des données ;
- Identifier et mettre en œuvre les procédures visant à traiter les cas de non-conformité ;
- Assurer la communication des mises à jour de la présente politique ;
- Mettre en place une organisation efficace afin de notifier d'éventuelles violations de données à caractère personnel auprès de l'autorité de contrôle, et, le cas échéant, auprès des personnes concernées ainsi que de définir les mesures à apporter ;
- Former et animer le réseau des Relais DPO afin d'installer les bonnes pratiques et veiller à la bonne application de la Politique de Protection des Données Personnelles au sein de chaque entité ;
- Contrôler de manière permanente, la bonne application des règles internes, procédures ou consignes relatives à la protection des données à caractère personnel au niveau de chaque entité du groupe ;
- Centraliser les résultats de contrôle et d'audit de l'application de la Politique de Protection des Données Personnelles et les rapports de manière que les autorités de protection des données puissent y accéder en cas de contrôle ;

- Être l'interlocuteur privilégié des autorités de contrôle sur les questions relatives aux traitements mis en œuvre par le groupe et mener des consultations, le cas échéant, sur tout autre sujet.

Le groupe a également nommé des relais DPO qui sont chargés de contribuer à la bonne application de la Politique de Protection des Données Personnelles au niveau local.

Le rôle du relais DPO consiste à :

- Relayer les communications à chaque entité : il est destinataire de toutes les informations importantes en provenance du DPO groupe ;
- Travailler en étroite collaboration avec le DPO groupe pour appliquer les règles internes de protection des données.
- Assurer et contrôler localement la bonne application des exigences de la Politique de Protection des Données Personnelles et reporter les résultats de contrôle/audit au DPO groupe ;
- Le relais DPO est l'interlocuteur au quotidien de son entité pour les questions relevant de la protection de données, et il a recours au DPO en cas de doutes ou de problèmes non résolus localement ;
- Informer le DPO groupe de toute mise en place et évolution d'un traitement de données à caractère personnel ;
- Coordonner et/ou prendre en charge la mise en œuvre locale des actions définies dans la Politique de Protection des Données Personnelles ;
- Relayer les questions et réponses concernant la protection de données entre le DPO et les collaborateurs, clients ou tout autre tiers bénéficiaire ;
- Informer le Comité conformité protection des données et le DPO groupe de toute action menée localement, plainte, violation des données ou de tout autre question/problème relevant du champ d'application de la Politique de Protection des Données Personnelles ;
- Informer le DPO en cas de contrôle de l'autorité de contrôle sur son périmètre.



Plan de continuité d'activité

Afin de remédier à toute indisponibilité, Owlance dispose d'un plan de continuité d'activité. La société effectue également une revue des plans mis en place par ses prestataires essentiels.

Owlance a identifié trois niveaux de sinistres afin d'aider à la décision de déclencher ou non le plan de continuité d'activité :

- **Incident mineur** : Ce type de sinistre est lié à une défaillance simple qui entraîne une réduction ou une interruption courte de l'activité. Dans ce type de situation, le PCA est déclenché mais la cellule de gestion de crise n'est pas mobilisée dans son intégralité.
- **Incident intermédiaire** : Il s'agit d'une interruption de l'activité supérieure à 48 heures. Le retour à la normale est réalisable en moins de 5 jours ouvrés. La cellule de gestion de crise est mobilisée dès la qualification du sinistre et pilote la mise en place des procédures de continuité d'activité ainsi que la reprise.
- **Incident majeur** : Interruption de l'activité supérieure à 5 jours ouvrés.
- La cellule de gestion de crise est mobilisée dès la qualification du sinistre et pilote la mise en place des procédures de continuité d'activité ainsi que la reprise.

Ce plan permet :

- De déterminer des sites de repli en cas d'indisponibilité supérieure à 48 heures,
- De concevoir des hypothèses de travail en cas de forte indisponibilité du personnel.

Des tests concernant le PCA sont régulièrement effectués. Des tests spécifiques à la demande des clients sont également réalisés.

Réponse du management aux exceptions identifiées

Objectif de contrôle #5			
Les contrôles en place permettent d'avoir une assurance raisonnable que les accès logiques sont restreints aux personnes préalablement autorisées.			
Ref. Ex	Ref. Ctrl	Ecart constaté	Réponse du management
D1	CO09	Incapacité à mener à bien le test en l'absence d'obtention des preuves demandées pour un échantillon de 20 incidents de traitements sélectionnés.	Constat de carence partagé.

Objectif de contrôle #6			
Les contrôles en place permettent d'avoir une assurance raisonnable que les accès logiques sont restreints aux personnes préalablement autorisées.			
Ref. Ex	Ref. Ctrl	Ecart constaté	Réponse du management
D2	CO10	Nous n'avons pas pu obtenir de preuves de sauvegarde pour 15 dates sur un échantillon total de 25 dates sélectionnées.	Depuis décembre 2023, les comptes-rendus de sauvegarde générés par Veeam Backup sont automatiquement envoyés et archivés dans une boîte mail dédiée.